

MARCO INTEGRATIVO GQM+ PRAGMATIC PARA CAsPeA

Alineación de Objetivos Nacionales con Métricas Técnicas de Ciberseguridad

Versión: 2.1

Fecha: Enero 2026

Audiencia: CISOs, Directivos, Investigadores de Ciberseguridad

Propósito: Establecer trazabilidad desde objetivos estratégicos nacionales hasta métricas operacionales CAsPeA

RESUMEN EJECUTIVO

Este marco integra dos metodologías complementarias:

1. GQM (Goal-Question-Metric): Enfoque top-down (1985, Basili/NASA) que alinea objetivos organizacionales con métricas medibles
2. PRAGMATIC: Nueve criterios (Glasgow et al., 2013) para evaluar la calidad/utilidad práctica de métricas

Sinergia: GQM define *QUÉ medir* (alineación); PRAGMATIC valida *SI es útil medirlo* (calidad métrica)

NIVEL 1: OBJETIVOS ESTRATÉGICOS NACIONALES (GOALS)

Goal 1: Cumplimiento Regulatorio Obligatorio

Definición estratégica:

Asegurar que 100% de operadores esenciales españoles cumplen NIS2 Anexo III, ENS, GDPR y DORA antes de auditorías regulatorias (Q2 2026+)

Contexto:

- Directiva NIS2 obligatoria enero 2026 → Multas €10-20M por incumplimiento
- 1.200 operadores esenciales + proveedores importantes afectados
- Responsabilidad regulatoria: CCN-CNI, AEPD, supervisores sectoriales

Objeto de medición: Organizaciones españolas (AAPP, operadores críticos, proveedores)

Goal 2: Cuantificación de Costes Reales de Seguridad

Definición estratégica:

Revelar y contabilizar los costes ocultos de personal en ciberseguridad (CAsPeA) para optimizar presupuestos nacionales y sectores

Contexto:

- España invertirá €2.7B-€3.1B anuales en ciberseguridad post-NIS2
- 60-70% será gasto de personal (hidden costs)
- Necesidad de justificación fiscal transparente

Objeto de medición: Personal de seguridad (dedicado, compartido, externalizado)

Goal 3: Mejora Continua de Madurez de Ciberseguridad

Definición estratégica:

Elevar IMG (Índice Madurez General) promedio sectorial de 52 (actual, Tier 2-3) a 70+ (Tier 3-4) en 36 meses

Contexto:

- Madurez heterogénea: Financiero (62) vs Manufactura (35)
- Brecha máxima: función RECOVER (35% cobertura, objetivo 80%)
- ROI proyectado de mejoras: 120-180%

Objeto de medición: Organismos (por sector, tamaño, criticidad)

Goal 4: Reducción de Riesgos Operacionales

Definición estratégica:

Reducir incidentes de ciberseguridad España en 40-60% en 24 meses mediante implementación de controles priorizados

Contexto:

- 2024: 97.348 incidentes reportados (+16,6% YoY)
- Coste promedio incidente: €240K-€500K
- Potencial ahorro anual: €600M-€1.2B

Objeto de medición: Incidentes (tipo, frecuencia, coste, causa)

NIVEL 2: PREGUNTAS ESTRATÉGICAS (QUESTIONS)

Cada Goal → 3-5 Questions que operacionalicen el objetivo

Goal 1: Cumplimiento Regulatorio

Q1.1: ¿Cuál es el nivel actual de cumplimiento NIS2 Anexo III por organización y sector?

- Métrica: % requisitos NIS2 implementados (M1.1)
- Métrica: Tier madurez por función NIST CSF (M1.2)

Q1.2: ¿Cuáles son las brechas críticas de cumplimiento normativo?

- Métrica: Número de controles "No Implementados" (M1.3)
- Métrica: Índice de riesgo regulatorio (M1.4)

Q1.3: ¿Cuál es el tiempo proyectado para alcanzar cumplimiento total?

- Métrica: Roadmap de remediación (meses, M1.5)
- Métrica: Costes de implementación de gaps (M1.6)

Goal 2: Cuantificación de Costes

Q2.1: ¿Cuál es el coste real anual de personal en ciberseguridad (CAsPeA)?

- Métrica: Coste total anual (€, M2.1)

- Métrica: Desglose por rol (CISO, Arquitecto, Analista, etc., M2.2)
- Métrica: Coste por empleado protegido (€/empleado, M2.3)

Q2.2: ¿Cómo se compara mi gasto contra pares sectoriales?

- Métrica: Percentil vs benchmarking sector (M2.4)
- Métrica: Ratio de insuficiencia presupuestaria (M2.5)

Q2.3: ¿Cuál es la distribución de costes entre funciones NIST CSF?

- Métrica: Coste por función (Govern, Identify, Protect, etc., M2.6)
- Métrica: Desbalance de inversión (si Detect >> Recover, M2.7)

Goal 3: Mejora de Madurez

Q3.1: ¿Cuál es el nivel de madurez actual (IMG) de mi organización?

- Métrica: IMG general (0-100, M3.1)
- Métrica: IMG por función NIST (6 valores, M3.2)

Q3.2: ¿Cuáles son las brechas de madurez vs objetivo (Tier 3)?

- Métrica: Brecha de cobertura % (M3.3)
- Métrica: Funciones bajo-maduras (<Tier 2, M3.4)

Q3.3: ¿Cuál es la velocidad de mejora esperada?

- Métrica: Tasa de mejora mensual (pp/mes, M3.5)
- Métrica: Tiempo proyectado a Tier 3 (meses, M3.6)

Goal 4: Reducción de Riesgos

Q4.1: ¿Cuál es la frecuencia actual de incidentes y tendencia?

- Métrica: Incidentes/año (M4.1)
- Métrica: Tasa de variación YoY (% , M4.2)

Q4.2: ¿Cuál es el impacto financiero de incidentes?

- Métrica: Coste total anual (€, M4.3)
- Métrica: Coste promedio por incidente (€, M4.4)

Q4.3: ¿Qué controles reducen más incidentes?

- Métrica: Incidentes evitados por control (M4.5)
- Métrica: ROI por control implementado (M4.6)

NIVEL 3: MÉTRICAS OPERACIONALES (METRICS)

Ejemplo detallado para una métrica CAsPeA crítica:

MÉTRICA M2.1: Coste Total Anual de Personal en Ciberseguridad (CAsPeA)

Definición:

Suma anual de costes de personal dedicado a actividades de ciberseguridad, desagregado por rol y categoría, incluyendo salarios, beneficios, y costes indirectos.

Fórmula:

$$\text{CASPeA Total} = \sum (\text{FTE}_{\text{rol}} \times \text{Salario}_{\text{rol}} \times (1 + \text{Beneficios\%}) \times (\text{Horas}_{\text{Seguridad}} / 1800))$$

para todos los roles dedicados y compartidos

Ejemplo cálculo:

CISO: $1.0 \text{ FTE} \times €75\text{K} \times 1.25 = €93.750$ (dedicado 100%)
Arquitecto: $2.0 \text{ FTE} \times €60\text{K} \times 1.25 = €150.000$ (dedicado 100%)
Admin IT (20% seguridad): $8.0 \text{ FTE} \times €40\text{K} \times 1.25 \times 0.20 = €80.000$

CASPeA Total = €323.750/año

Validación de PRAGMATIC:

Criterio PRAGMATIC	Evaluación	Justificación
Predictivo	✓ Alta	Correlaciona con madurez de seguridad; mayor CASPeA → mejor detección
Relevante	✓ Alta	Crítico para CFO, justificación presupuestaria
Accionable	✓ Alta	CISO puede contratar, entrenar, externalizar
Genuino	✓ Alta	Datos de nómina verificables, no ambiguo
Significativo	✓ Alta	Impacta decisiones presupuestarias, 60-70% gasto seguridad
Preciso	✓ Media-Alta	±5% con datos de RRHH; si usa estimaciones, ±20%
Oportuno	✓ Media	Disponible trimestralmente (con lag de 1 mes)
Independiente	✓ Alta	No correlaciona con otras métricas; independencia estadística
Rentable	✓ Alta	Bajo coste (datos de nómina internos)

Puntuación PRAGMATIC Total: 8.3/9 (EXCELENTE)

TRAZABILIDAD INTEGRADA: DE OBJETIVOS A DATOS

Ejemplo End-to-End: NIS2 Compliance → MTTD Improvement

NIVEL 1: GOAL

Goal: Cumplir NIS2 Anexo III (Requisito Esencial 4: "Capacidad de detección de anomalías")

Impacto: Auditoría regulatoria pasada / evitar multas

Plazo: Q1 2026 (auditoría esperada Q2)



NIVEL 2: QUESTIONS

Q4.1: ¿Cuál es MTTD actual? → Respuesta: 120 minutos

Q4.2: ¿Cumple NIS2? → No (objetivo: <60 min)

Q4.3: ¿Cómo mejorar MTTD? → Automatización SIEM



NIVEL 3: METRICS

M4.1: MTTD actual = 120 minutos

M4.2: MTTD objetivo NIS2 = 60 minutos

M4.3: Brecha MTTD = 60 minutos (100% mejora)

M4.4: Coste mejora (CAsPeA) = €180K (especialistas+tool)

M4.5: ROI = (€612K pérdida evitada) / €180K = 240%

ACCIÓN: Autorizar €180K para SIEM upgrade

TIMELINE: 6 meses a MTTD 70 minutos (meta Q2 26)

MATRIZ DE INTEGRACIÓN GQM+PRAGMATIC

Goal	Question	Métrica	Criterio PRAGMATIC Crítico	Validación
Cumpl. NIS2	¿% impl. NIS2?	M1.1: % controles	Relevante (regulador)	✓ Auditor
CAsPeA	¿Coste anual?	M2.1: Coste total	Genuino (datos nómina)	✓ CFO
Madurez	¿IMG actual?	M3.1: IMG 0-100	Accionable (guía mejora)	✓ CISO
Riesgos	¿Incidentes/año?	M4.1: Frecuencia	Predictivo (trending)	✓ CRO

IMPLEMENTACIÓN PRÁCTICA: 5 PASOS

Paso 1: Mapear Goals a Estrategia Nacional

Objetivo Nacional → Goal → Questions → Metrics

"Elevar madurez sector financiero" → Goal 3 → Q3.1-3.3 → M3.1-3.6

Paso 2: Definir Questions Específicas al Contexto

Contexto: Banco 500 empleados, financiero, DORA

Pregunta específica: "¿MTTD cumple DORA (<1h)?"

Métrica: M4.1 = MTTD actual vs 60 minutos

Paso 3: Validar Cada Métrica contra PRAGMATIC

Métrica: "Porcentaje de patches críticos aplicados en <7 días"

Predictivo: ✓ (correlaciona con breaches)

Relevante: ✓ (cumplimiento NIS2)

Accionable: ✓ (equipo IT puede automatizar)

... (aplicar todos 9)

Puntuación: 7.5/9 → IMPLEMENTAR

Paso 4: Recopilar Datos Sistemáticamente

Métrica M2.1 (CASPeA): Fuente = Nómina (RRHH)

Métrica M4.1 (MTTD): Fuente = SIEM logs

Métrica M3.1 (IMG): Fuente = Encuesta CRA-Cyber

Frecuencia: Trimestral (consolidado)

Paso 5: Reportar con Trazabilidad Visible

REPORTE EJECUTIVO:

"Objetivo nacional: Cumplir NIS2

Goal: Capacidad detección anomalías

Question: ¿MTTD actual cumple?

Métrica: MTTD = 95 min (mejora desde 120)

Status: En curso (objetivo 60 min, Q2 2026)

Acción: Automatización SIEM (€180K, aprobado)"

BENEFICIOS DE INTEGRACIÓN GQM+PRAGMATIC

- ✓ **Trazabilidad completa:** Cada dato técnico vincula a objetivo estratégico
- ✓ **Decisiones defensibles:** Métricas validadas contra 9 criterios de calidad
- ✓ **Alineación multi-nivel:** Goals nacionales → Org → Proyecto → Técnico
- ✓ **Mejora continua:** Feedback loop: Goal → Data → Learning → Goal refinado
- ✓ **Reducción de vanity metrics:** Solo métricas PRAGMATIC implementadas

Marco Integrativo GQM+ PRAGMATIC v2.1 para CAsPeA